ПРУФ-ИТ / PROOFIT

Информационная безопасность и персональные данные

Privacy-by-design, проверяемые технические меры и обязанности оператора.

Редакция документа: 11 октября 2026. Архитектурные утверждения связаны с указанными модулями; числовые результаты — с протоколами измерений, их датами и областью применимости. Обновление документа не означает повторного проведения всех экспериментов.

Роли: специалист, работодатель, явно одобренный эксперт. Окончательное решение о найме, трактовка спорного evidence и разрешение на обработку данных не передаются автономному score.

1. Политика доступа

Все чувствительные операции выполняются через authenticated Actor с role и subject_id. Владение проверяется на сервере и в SQL scope. Проверенный работодатель видит только поисково-доступные профессиональные данные при действующих согласиях. Личные файлы и private conversation никогда не раскрываются только потому, что человек присутствует в public search.

Согласия разделены: обработка, публикация, контактный обмен. Отзыв не является только флагом в интерфейсе: API перестает раскрывать соответствующие данные. Принятие приглашения создает разрешенный предметный контекст; третья компания не наследует контактное согласие. Зарплаты — диапазоны RUB, а не скрытые контактные сведения.

2. Карта данных и минимизация

Категория	Хранение / использование	Ограничение
Email, имя, пароль	users; Argon2 hash; подтверждение почты	Не вход ranking/twin; hash не экспортируется
Контакты и документы	private storage + owner metadata	Не в web root; только owner file routes
Профили / условия	resume_profiles, companies, vacancies	Publication и ownership scope
Сертификаты / ответы	qualification ledger / traces	Role-bound; expiry; revoke; current item only
Код / task context	arena/microtask, scoped fingerprints	Hidden tests не возвращаются; task-specific compare
Предпочтения	intelligence.preferences / company_twins	Voluntary work fields; no inferred personality
Provider data	verified snapshots + source URL + date	Not connected → neutral; no fabricated records
Passports / outcomes	Signed token digest; bilateral feedback	No direct PII; live revocation; invitation scope

3. Учетные записи, сессии и CSRF

Пароли обрабатываются Argon2, сессии в БД представлены hash токена, срок браузерной сессии — 12 часов. В HTTPS применяется __Host- cookie, Secure, HttpOnly, SameSite=Strict. Изменение пароля и отзыв сессий инвалидируют доступ через auth_epoch. Host/Origin проверяются; передаваемые клиентом forwarding headers не принимаются как личность.

OIDC callback — узкое исключение cross-site navigation: он защищен one-time state, PKCE S256, nonce, browser binding, issuer/audience и подписью ID-token. Email claim не является достаточным основанием для автоматического объединения учетных записей. Gateway сохраняет несколько Set-Cookie заголовков, что нужно настоящему Keycloak login-flow.

4. Реальный Keycloak

В deploy/keycloak.compose.yml развернут Keycloak 26.8.0 с отдельным PostgreSQL volume, confidential client, exact redirect, PKCE, запретом implicit/direct grant, ротацией refresh token, коротким access token и brute-force protection. Admin и master realm не доступны через публичный gateway. Секреты сгенерированы независимо и вынесены в ignored runtime files.

Full authorization-code flow проверен через настоящий login form и JWKS, включая callback replay и другой browser subject. Локальная HTTP-конфигурация и внешний HTTPS-профиль не смешиваются: configure_keycloak_origin обновляет redirect и SSL requirement при смене origin. Эксплуатация SMTP, MFA, backup identity DB и admin ACL остается отдельной обязанностью оператора. [KC]

5. Файлы, OCR и AI

Файл ограничивается по типу/размеру и записывается под server storage key; контрольная сумма связывает содержимое с записью. API file route проверяет user_id. Извлечение содержит provenance и reviewed fields; пользователь подтверждает данные, вместо незаметного переписывания профиля.

Контактные и идентифицирующие фрагменты редактируются перед отдельными AI-review операциями. LLM не сертифицирует mandatory CAT, не читает database secrets и не выполняет инструкции из PDF как полномочия. Документы на диске и основной PostgreSQL не объявляются полностью зашифрованными приложением: disk encryption, ACL и backup protection задаются средой размещения. AES-GCM применяется к отдельным интеграционным/почтовым секретам, а не ко всей базе.

6. Недоверенный код

Sandbox: Docker container non-root 65534; network=none; read-only root; cap-drop ALL; no-new-privileges; no host mounts/secrets; memory/swap 128 MB; CPU 0.5; PID 32; bounded file descriptors, tmpfs, output and timeout. После выполнения удаляется конкретный контейнер с уникальным proofit-run ID.

Sandbox output проверяется доверенным worker с server expected values; hidden expected/actual не выходят в public DTO. Изоляция container — прикладной барьер, не доказанная граница против всех kernel exploits. Для промышленного приема кода рекомендуется выделенный patched executor host/VM и запрет Docker socket в публичном домене.

7. Правовая карта ПДн

Базовый ориентир — действующая редакция 152-ФЗ: цель и основание обработки, минимизация, права субъекта, защита, предусмотренные законом обязанности оператора и правила размещения/передачи. Обработка, публикация и раскрытие контактов не объединяются в одно техническое согласие. Юридическое соответствие зависит от фактического оператора и эксплуатации, а не от названия модуля. [PD]

До обработки реальных персональных данных оператор определяет правовое основание, тексты согласий и политики, сроки хранения и удаления, применимость уведомлений и допустимость внешних обработчиков. Тестовый набор содержит синтетические профили и пустые контакты. Он не основание для загрузки любых чужих реальных документов без полномочий.

Quick Tunnel передает HTTP через инфраструктуру Cloudflare и завершает внешний TLS. Для демонстрации предпочтительны синтетические/обезличенные данные; реальные резюме требуют отдельной оценки допустимости внешней обработки и передачи. Постоянный production ingress с контролируемым размещением заменяет временный tunnel, если этого требует выбранный режим обработки.

8. Экспорт, удаление и retention

/account/export возвращает owned records без password/session secrets, hidden tests и reference solutions. Существуют owner deletion routes; dependent identity records очищаются по каскадам. Отдельный portable proof может быть отозван раньше срока. Records 30/60/90 доступны только двум участникам принятого предложения.

Retention — операторская политика, а не безграничное хранение «на всякий случай». Backup, audit и внешняя передача в ATS учитываются отдельно при запросе удаления; экспорт не доказывает автоматическое удаление всех резервных копий. До production оператор устанавливает TTL по целям, регламент исполнения запросов и проверяемый журнал результата.

9. Инцидент и восстановление

При подозрении на account compromise: отозвать сессии, изолировать затронутую интеграцию, сохранить разрешенный audit context, перевыпустить credentials и проверить повторный доступ. При компрометации passport key — сменить issuer/key version, отозвать затронутые live passports и уведомить проверяющих. При sandbox incident — отключить executor, оставить retrieval работающим, исследовать конкретный контейнер/host.

Backup protocol: согласованная копия БД + storage + ключи отдельно; restore в новую изолированную БД, сравнение счетчиков и SHA файлов, никаких restore поверх рабочей БД. Наличие backup_verify.py означает процедуру; факт восстановления утверждается только при наличии актуального backup-results artifact. Audit текущего приложения не именуется криптографически неизменяемым журналом.

10. Проверяемая security posture

Модель угроз — 05_Threat_Model.pdf. Evidence — HTTP и CPU suites; source entry points — src/security.rs, auth.rs, account.rs, documents.rs, certification.rs, evidence.rs, professional.rs, intelligence/oidc.py, providers.py, worker/workbench.py. Публичное описание не содержит секретов, private адресов БД или учетных паролей.

11. Допуск к обнаружению не является контактным согласием

Публичность, актуальное доказательство категории и grant контактов проверяются раздельно. Отзыв сертификата исключает новую выдачу/приглашение, но не выдает автоматически право стереть уже предоставленное контактное согласие; отзыв самого контакта по-прежнему имеет отдельный приоритет. Автор может видеть свое резюме независимо от готовности к discovery.

12. Проспективные данные: владение и удаление

Frozen prediction доступен владельцу вакансии; собственный account export кандидата включает относящийся к нему снимок и первый исход. Посторонний работодатель не получает чужой export. Ограниченный numerical payload содержит только модельный контекст, идентификаторы пары и timestamps, без контактов. FK ON DELETE CASCADE удаляет snapshot/outcome при удалении связанных объектов. Детерминированный source digest не объявляется анонимизацией: идентификаторы остаются в защищённой области.

13. Привязка аккаунта и доказательства

Контроль аккаунта подтверждается одноразовым публичным gist: 64-символьный код, proofit-claim.txt, срок 600 секунд, соответствие GitHub ID владельца и однократное потребление хеша в транзакции. GitHub ID может быть привязан только к одной учётной записи платформы. Публичный gist после проверки можно удалить. Это доказательство контроля аккаунта, а не самостоятельное доказательство авторства кода.

Снимок фиксирует head SHA, изменённые файлы, коммиты и обсуждение. Head проверяется до и после чтения; движение во время импорта отвергается. SHA-256 канонического снимка связывает вопрос, фрагмент изменений и экспертную оценку. Детерминированный artifact-aware агент строит вопросы по имени файла, hunk, изменённым строкам и конкретному критерию роли. Полученный из репозитория текст не интерпретируется как управляющие инструкции.

14. Подозрительные паттерны как повод для разбора

Контролируются быстрые правильные последовательности, практически идентичное серверное время и сочетание малой ожидаемой вероятности с быстрым успехом. Пороговая модель авторская, не популяционно откалиброванная. Сигналы сохраняются в независимую очередь review_cases, не объявляют плагиат, не отзывают прежние сертификаты и не выполняют кадровую санкцию.

Разбор учитывает доступность интерфейса, сетевую буферизацию, знакомство с предметом и точность инструментирования. Неблагоприятный вывод требует одобренного независимого reviewer и проверяемого основания. Пользователь вправе оспорить вывод; ранее установленный факт сохраняется до независимого пересмотра. Проверка знаний с сигналом требует подтверждения контекста, а не автоматически становится профессиональной аттестацией.

15. Выбранный публичный артефакт и жизненный цикл

GitHub импортируется по действию кандидата для определённого резюме. Контакты не индексируются, код не исполняется, секрет оператора не попадает в браузер. Snapshot/ответы/состояние включены в собственный account export; удаление связанных пользователя, резюме или кандидата каскадно удаляет соответствующие записи. Public provenance не означает свободную перепубликацию чужой лицензии и не превращается в базу контактов. Границы внешней API-политики и сроки хранения определяет оператор.

16. Единый авторизованный контур проверки

Проверка платформы выполняется через штатную авторизацию: по отдельно переданным данным тестовых кабинетов либо после собственной регистрации. Сессия, серверная роль и принадлежность данных проверяются обычными обработчиками. Вход в другую роль требует учетных данных ее кабинета; гостевого входа, автоматической смены identity и анонимной выдачи паролей нет. Синтетические резюме и вакансии сохраняются без пересоздания пользователей. Прежние гостевые сессии отозваны миграцией 0030 без удаления данных. Такая организация делает границы доступа частью проверяемого пользовательского маршрута. Протокол и область измерений — 11_Interface_and_Demo.pdf.